Your Car Your Way

Compliance assessment

Chrystopher Deregnaucourt
02/2026

Table des matières

1. Composants logiciels 3
1.1 Service d'authentification (Auth Service) 3
1.2 Service de profil utilisateur 4
1.3 Service de réservation (Booking Service) 6
1.4 Service de support (Support Service) 8
1.5 Service de notifications (Notification Service) 9
1.6 Internationalisation 10
2. Services ou composants tiers logiciels 11
2.1 Service de paiement (Stripe) 11
2.2 Service de visioconférence (Twilio) 11
2.3 Services OAuth (SSO) 12
2.4 Service d'envoi d'emails (SendGrid/SES) 12
3. Gestion des données 13
3.1 Base de données PostgreSQL 13
3.2 Cache Redis 14
3.3 Stockage fichiers S3 14
3.4 Conformité RGPD 15
4. Infrastructure 16
4.1 Réseau et connectivité 16
4.2 Conteneurs et orchestration 17
4.3 CI/CD 17
4.4 Monitoring et logging 18
5. Sécurité 18
5.1 Authentification et autorisation 18
5.2 Communication sécurisée 19
5.3 Protection contre les attaques 19
5.4 Gestion des secrets 20
5.5 Conformité PCI DSS 20
Synthèse des contrôles 21
Matrice de traçabilité 22

Description générale de l'architecture

Ce document évalue la conformité de l'architecture définie pour le projet **Your Car Your Way** par rapport aux exigences fonctionnelles et techniques établies dans les documents Business Requirements V2 et Architecture Definition Document.

Cadre architectural

L'architecture repose sur les principes suivants :

- **Architecture microservices** avec 6 services principaux (Auth, Booking, Support, Payment, Notification, Internal API)
- **Déploiement cloud AWS** avec ECS Fargate, RDS PostgreSQL, Redis, Elasticsearch
- **Communication temps réel** via Spring WebSocket STOMP (chat) et Twilio (visioconférence)
- **API RESTful** documentée pour l'interopérabilité avec les systèmes internes
- **Conformité réglementaire** RGPD et PCI DSS

Liste de contrôle de l'architecture terminée

1. Composants logiciels

1.1 Service d'authentification (Auth Service)

ID	Contrôle	Critère d'acceptation	Priorité
AUTH-001	Inscription par email	L'utilisateur peut créer un compte avec email, mot de passe, nom, prénom, date de naissance, téléphone, pays	Haute
AUTH-002	Validation email	Un email de validation est envoyé avec un lien de confirmation valide 24h	Haute
AUTH-003	Inscription SSO	L'utilisateur peut s'inscrire via Google, Apple, Facebook	Moyenne
AUTH-004	Connexion standard	L'utilisateur peut se connecter avec email et mot de passe	Haute
AUTH-005	Connexion SSO	L'utilisateur peut se connecter via Google, Apple, Facebook	Moyenne
AUTH-006	Session persistante	L'option "Se souvenir de moi" maintient la session 30 jours	Basse
AUTH-007	Déconnexion	L'utilisateur peut se déconnecter, la session est invalidée	Haute
AUTH-008	Réinitialisation mot de passe	Un lien de réinitialisation est envoyé par email, valide 1h	Haute
AUTH-009	Authentification 2FA	L'utilisateur peut activer le 2FA par SMS ou application TOTP	Moyenne
AUTH-010	Historique connexions	L'utilisateur peut consulter les 10 dernières connexions (IP, date, appareil)	Basse
AUTH-011	Déconnexion toutes sessions	L'utilisateur peut invalider toutes les sessions actives	Moyenne
AUTH-012	Politique de mot de passe	Le mot de passe respecte les critères : 8 caractères minimum, majuscule, minuscule, chiffre, caractère spécial	Haute
AUTH-013	Verrouillage compte	Le compte est verrouillé après 5 tentatives échouées pendant 15 minutes	Haute
AUTH-014	Token JWT	Les tokens JWT ont une durée de vie de 1h (access) et 7 jours (refresh)	Haute

1.2 Service de profil utilisateur

ID	Contrôle	Critère d'acceptation	Priorité
PROF-001	Consultation profil	L'utilisateur peut voir toutes ses informations personnelles	Haute
PROF-002	Modification informations	L'utilisateur peut modifier nom, prénom, adresse, téléphone	Haute
PROF-003	Modification email	Le changement d'email nécessite la validation des deux adresses	Haute
PROF-004	Modification mot de passe	Le changement de mot de passe nécessite l'ancien mot de passe	Haute
PROF-005	Photo de profil	L'utilisateur peut uploader une photo (max 5MB, formats JPG/PNG)	Basse
PROF-006	Ajout permis	L'utilisateur peut ajouter son permis avec numéro, dates, pays, photos	Haute
PROF-007	Modification permis	L'utilisateur peut modifier les informations de son permis	Moyenne
PROF-008	Ajout moyen de paiement	L'utilisateur peut ajouter une carte via Stripe Elements	Haute
PROF-009	Liste moyens de paiement	Les numéros de carte sont masqués (affichage des 4 derniers chiffres)	Haute
PROF-010	Paiement par défaut	L'utilisateur peut définir un moyen de paiement par défaut	Moyenne
PROF-011	Suppression paiement	L'utilisateur peut supprimer un moyen de paiement	Moyenne
PROF-012	Préférences langue	L'utilisateur peut choisir parmi EN, FR, DE, ES, IT	Haute
PROF-013	Préférences devise	L'utilisateur peut choisir parmi EUR, GBP, USD	Haute
PROF-014	Demande suppression compte	L'utilisateur peut demander la suppression (mot de passe requis)	Haute
PROF-015	Délai suppression	Un délai de 7 jours est appliqué avant suppression définitive	Haute
PROF-016	Annulation suppression	L'utilisateur peut annuler la demande pendant les 7 jours	Moyenne

PROF-017	Blocage suppression	La suppression est bloquée si réservation en cours ou à venir	Haute

1.3 Service de réservation (Booking Service)

ID	Contrôle	Critère d'acceptation	Priorité
BOOK-001	Liste agences	La liste des agences est affichée avec nom, adresse, coordonnées, horaires	Haute
BOOK-002	Recherche agences	La recherche fonctionne par ville, code postal, ou géolocalisation	Haute
BOOK-003	Formulaire recherche	Le formulaire contient : ville départ/retour, dates/heures, catégorie	Haute
BOOK-004	Affichage résultats	Les offres sont affichées avec véhicule, prix, caractéristiques	Haute
BOOK-005	Filtres résultats	Les filtres fonctionnent : prix, transmission, carburant, places, options	Moyenne
BOOK-006	Tri résultats	Le tri fonctionne par prix et catégorie	Moyenne
BOOK-007	Détail offre	Le détail affiche toutes les caractéristiques, photos, conditions	Haute
BOOK-008	Catégories ACRISS	Les véhicules sont classés selon la norme ACRISS	Haute
BOOK-009	Sélection options	L'utilisateur peut ajouter GPS, siège enfant, conducteur additionnel	Moyenne
BOOK-010	Récupération profil	Les informations du profil sont pré-remplies si disponibles	Moyenne
BOOK-011	Paiement sécurisé	Le paiement est effectué via Stripe avec 3D Secure	Haute
BOOK-012	Confirmation réservation	Un email de confirmation est envoyé avec numéro et QR code	Haute
BOOK-013	Historique réservations	L'historique affiche réservations passées, en cours, à venir, annulées	Haute
BOOK-014	Détail réservation	Le détail complet d'une réservation est accessible	Haute
BOOK-015	Modification réservation	La modification est possible jusqu'à 48h avant le début	Haute
BOOK-016	Annulation réservation	L'annulation est possible avec affichage du montant remboursé	Haute
BOOK-017	Remboursement 100%	Remboursement total si annulation > 7 jours avant	Haute

BOOK-018	Remboursement 25%	Remboursement 25% si annulation entre 7 jours et 48h	Haute
BOOK-019	Pas de remboursement	Aucun remboursement si annulation < 48h	Haute
BOOK-020	Téléchargement facture	La facture PDF est téléchargeable pour les locations passées	Moyenne
BOOK-021	Export calendrier	L'export iCal fonctionne pour les réservations	Basse
BOOK-022	Évaluation globale	L'utilisateur peut noter une location passée de 1 à 5 étoiles	Moyenne
BOOK-023	Commentaire évaluation	L'utilisateur peut ajouter un commentaire optionnel à son évaluation	Moyenne
BOOK-024	Évaluation détaillée	L'utilisateur peut évaluer séparément le véhicule et le service en agence	Moyenne
BOOK-025	Historique évaluations	L'utilisateur peut consulter ses évaluations passées	Basse

1.4 Service de support (Support Service)

ID	Contrôle	Critère d'acceptation	Priorité
SUPP-001	Formulaire contact	Le formulaire contient sujet, réservation associée, message, pièces jointes	Haute
SUPP-002	Historique conversations	L'historique des tickets est accessible avec statut	Haute
SUPP-003	Réponse ticket	L'utilisateur peut répondre dans une conversation existante	Haute
SUPP-004	Notification réponse	Une notification est envoyée lors d'une réponse du support	Haute
SUPP-005	Pièces jointes	L'upload de fichiers fonctionne (max 10MB, formats PDF/JPG/PNG)	Moyenne
SUPP-006	Démarrage chat	L'utilisateur peut démarrer une session de chat	Haute
SUPP-007	Chat temps réel	Les messages sont échangés en temps réel via Spring WebSocket (STOMP)	Haute
SUPP-008	File d'attente	La position dans la file et le temps estimé sont affichés	Moyenne
SUPP-009	Indicateur typing	L'indicateur "en train d'écrire" fonctionne	Basse
SUPP-010	Partage fichiers chat	Le partage de fichiers fonctionne pendant le chat	Moyenne
SUPP-011	Transcription chat	Une transcription est envoyée par email à la fin de session	Moyenne
SUPP-012	Évaluation chat	L'utilisateur peut noter la session (1-5 étoiles) et commenter	Moyenne
SUPP-013	Demande visio	L'utilisateur peut demander un appel en visioconférence	Haute
SUPP-014	Planification visio	L'utilisateur peut choisir un créneau disponible	Haute
SUPP-015	Session visio	La vidéo et l'audio bidirectionnels fonctionnent	Haute
SUPP-016	Annulation visio	L'utilisateur peut annuler ou reporter le rendez-vous	Moyenne
SUPP-017	Évaluation visio	L'utilisateur peut noter l'appel et commenter	Moyenne
SUPP-018	FAQ	La FAQ est accessible et consultable	Moyenne
SUPP-019	Recherche aide	La recherche dans les articles d'aide fonctionne	Basse

1.5 Service de notifications (Notification Service)

ID	Contrôle	Critère d'acceptation	Priorité
NOTIF-001	Email inscription	Un email de bienvenue est envoyé après inscription	Haute
NOTIF-002	Email réservation	Un email de confirmation est envoyé après réservation	Haute
NOTIF-003	Rappel 48h	Un rappel est envoyé 48h avant la location	Haute
NOTIF-004	Rappel 24h	Un rappel est envoyé 24h avant la location	Haute
NOTIF-005	Email modification	Un email est envoyé après modification de réservation	Haute
NOTIF-006	Email annulation	Un email est envoyé après annulation avec détails remboursement	Haute
NOTIF-007	Email facture	La facture est envoyée après la fin de la location	Haute
NOTIF-008	Notification support	Une notification est envoyée pour les réponses du support	Haute
NOTIF-009	Push browser	Les notifications push navigateur fonctionnent	Moyenne
NOTIF-010	Préférences email	L'utilisateur peut activer/désactiver les emails par catégorie	Moyenne
NOTIF-011	Préférences push	L'utilisateur peut activer/désactiver les notifications push	Moyenne
NOTIF-012	Désabonnement marketing	Le lien de désabonnement fonctionne dans les emails	Haute

1.6 Internationalisation

ID	Contrôle	Critère d'acceptation	Priorité
I18N-001	Support multilingue	L'application supporte les langues : EN, FR, DE, ES, IT	Haute
I18N-002	Support multi-devises	Les prix s'affichent en EUR, GBP, USD selon la préférence utilisateur	Haute
I18N-003	Formats date/heure	Les formats de date et d'heure s'adaptent à la locale de l'utilisateur	Haute
I18N-004	Gestion fuseaux horaires	Les fuseaux horaires sont gérés correctement pour les réservations internationales	Haute
I18N-005	Contenu régional	Le contenu est adapté aux spécificités régionales (réglementations, conditions)	Moyenne

1.7 Service API interne (Internal API Service)

ID	Contrôle	Critère d'acceptation	Priorité
API-001	Authentification API	L'API interne est protégée par OAuth 2.0 / JWT (client credentials) avec scopes/roles agence	Haute
API-002	Documentation OpenAPI	Les endpoints sont documentés et consultables (OpenAPI/Swagger)	Haute
API-003	CRUD domaines	Les opérations CRUD sont disponibles pour utilisateurs, réservations, agences et catalogue d'offres (catégories/modèles)	Haute
API-004	Traçabilité	Toutes les opérations sensibles sont journalisées (audit logs) avec identifiant applicatif et horodatage	Moyenne
API-005	Protection & quotas	Rate limiting et quotas par client applicatif sont appliqués, avec gestion d'erreurs standardisée	Moyenne

2. Services ou composants tiers logiciels

2.1 Service de paiement (Stripe)

ID	Contrôle	Critère d'acceptation	Priorité
PAY-001	Intégration Stripe	Les paiements sont traités via l'API Stripe	Haute
PAY-002	Stripe Elements	Le formulaire de carte utilise Stripe Elements (PCI compliant)	Haute
PAY-003	3D Secure	L'authentification 3D Secure est activée	Haute
PAY-004	Webhooks Stripe	Les webhooks de confirmation de paiement sont traités	Haute
PAY-005	Remboursements	Les remboursements partiels et totaux fonctionnent via Stripe	Haute
PAY-006	Gestion erreurs	Les erreurs de paiement sont gérées et affichées clairement	Haute
PAY-007	Multi-devises	Les paiements fonctionnent en EUR, GBP, USD	Haute

2.2 Service de visioconférence (Twilio)

ID	Contrôle	Critère d'acceptation	Priorité
VIDEO-001	Intégration Twilio	Les appels vidéo utilisent Twilio Video SDK	Haute
VIDEO-002	Création room	Une room Twilio est créée pour chaque session	Haute
VIDEO-003	Token d'accès	Les tokens d'accès sont générés côté serveur	Haute
VIDEO-004	Qualité adaptative	La qualité vidéo s'adapte à la bande passante	Moyenne
VIDEO-005	Fallback audio	Le fallback en audio seul fonctionne si vidéo impossible	Moyenne

2.3 Services OAuth (SSO)

ID	Contrôle	Critère d'acceptation	Priorité
SSO-001	Google OAuth	L'authentification via Google fonctionne	Haute
SSO-002	Apple Sign In	L'authentification via Apple fonctionne	Haute
SSO-003	Facebook Login	L'authentification via Facebook fonctionne	Moyenne
SSO-004	Liaison compte	Un compte SSO peut être lié à un compte existant	Moyenne
SSO-005	Récupération données	Le nom et l'email sont récupérés du provider SSO	Haute

2.4 Service d'envoi d'emails (SendGrid/SES)

ID	Contrôle	Critère d'acceptation	Priorité
EMAIL-001	Envoi transactionnel	Les emails transactionnels sont envoyés < 5 secondes	Haute
EMAIL-002	Templates	Les templates HTML sont utilisés pour tous les emails	Haute
EMAIL-003	Multi-langue	Les emails sont envoyés dans la langue de l'utilisateur	Haute
EMAIL-004	SPF/DKIM	Les enregistrements SPF et DKIM sont configurés	Haute
EMAIL-005	Taux de délivrabilité	Le taux de délivrabilité est > 99%	Haute
EMAIL-006	Lien désabonnement	Chaque email marketing contient un lien de désabonnement	Haute

3. Gestion des données

3.1 Base de données PostgreSQL

ID	Contrôle	Critère d'acceptation	Priorité
DATA-001	Schéma normalisé	Le schéma respecte la 3ème forme normale	Haute
DATA-002	Intégrité référentielle	Les contraintes de clés étrangères sont en place	Haute
DATA-003	Index optimisés	Les index sont créés sur les colonnes fréquemment recherchées	Haute
DATA-004	Types énumérés	Les types énumérés sont utilisés pour les statuts	Moyenne
DATA-005	Timestamps	Toutes les tables ont created_at et updated_at	Haute
DATA-006	UUID	Les identifiants primaires sont des UUID v4	Haute
DATA-007	Soft delete	La suppression logique est utilisée pour les données sensibles	Moyenne
DATA-008	Backup automatique	Les sauvegardes automatiques sont configurées (quotidien, 7 jours)	Haute
DATA-009	Point-in-time recovery	La restauration point-in-time est possible sur 7 jours	Haute
DATA-010	Multi-AZ	La réplication Multi-AZ est active en production	Haute

3.2 Cache Redis

ID	Contrôle	Critère d'acceptation	Priorité
CACHE-001	Sessions utilisateur	Les sessions sont stockées dans Redis	Haute
CACHE-002	TTL sessions	Les sessions expirent après 30 minutes d'inactivité. Le "remember me" s'appuie sur un refresh token (jusqu'à 30 jours) tout en conservant le timeout d'inactivité	Haute
CACHE-003	Cache requêtes	Les requêtes fréquentes sont mises en cache (TTL 5 min)	Moyenne
CACHE-004	Rate limiting	Le rate limiting utilise Redis (compteurs avec TTL)	Haute
CACHE-005	Pub/Sub	Le pub/sub Redis est utilisé pour les notifications temps réel	Moyenne
CACHE-006	Persistence	La persistence RDB est activée (snapshot toutes les 5 min)	Moyenne

3.3 Stockage fichiers S3

ID	Contrôle	Critère d'acceptation	Priorité
S3-001	Upload sécurisé	Les uploads utilisent des URLs pré-signées	Haute
S3-002	Types de fichiers	Seuls les types autorisés sont acceptés (JPG, PNG, PDF)	Haute
S3-003	Taille maximale	La taille maximale par fichier est 10MB	Haute
S3-004	Organisation buckets	Les fichiers sont organisés par type et utilisateur	Moyenne
S3-005	Lifecycle	Les fichiers temporaires sont supprimés après 30 jours	Basse
S3-006	CDN CloudFront	Les images sont servies via CloudFront	Haute

3.4 Conformité RGPD

ID	Contrôle	Critère d'acceptation	Priorité
RGPD-001	Consentement	Le consentement explicite est recueilli à l'inscription	Haute
RGPD-002	Droit d'accès	L'utilisateur peut exporter ses données (JSON)	Haute
RGPD-003	Droit à l'oubli	La suppression de compte efface toutes les données personnelles	Haute
RGPD-004	Droit de rectification	L'utilisateur peut modifier ses données personnelles	Haute
RGPD-005	Minimisation	Seules les données nécessaires sont collectées	Haute
RGPD-006	Durée de conservation	Les données sont supprimées après 5 ans d'inactivité	Moyenne
RGPD-007	Registre traitement	Le registre des traitements est documenté	Haute
RGPD-008	DPO	Un DPO est désigné et ses coordonnées sont accessibles	Haute
RGPD-009	Notification violation	La procédure de notification de violation < 72h est documentée	Haute
RGPD-010	Localisation données	Les données personnelles sont hébergées dans la région correspondant au marché : UE (eu-west-1) et USA (us-east-1), avec séparation des bases et résidence des données par région	Haute

4. Infrastructure

4.1 Réseau et connectivité

ID	Contrôle	Critère d'acceptation	Priorité
INFRA-001	VPC isolé	L'application est déployée dans un VPC dédié	Haute
INFRA-002	Sous-réseaux privés	Les services backend sont dans des sous-réseaux privés	Haute
INFRA-003	NAT Gateway	L'accès internet sortant passe par NAT Gateway	Haute
INFRA-004	Load balancer	L'ALB distribue le trafic entre les instances	Haute
INFRA-005	Health checks	Les health checks HTTP sont configurés (interval 30s)	Haute
INFRA-006	Auto-scaling	L'auto-scaling est configuré (min 2, max 10 tasks par service)	Haute
INFRA-007	Multi-AZ	Le déploiement utilise au minimum 2 zones de disponibilité	Haute

4.2 Conteneurs et orchestration

ID	Contrôle	Critère d'acceptation	Priorité
CONT-001	Images Docker	Toutes les applications sont containerisées	Haute
CONT-002	Base images	Les images de base sont officielles et à jour	Haute
CONT-003	Registry ECR	Les images sont stockées dans AWS ECR	Haute
CONT-004	Scan vulnérabilités	Le scan de vulnérabilités ECR est activé	Haute
CONT-005	ECS Fargate	Les containers tournent sur ECS Fargate (serverless)	Haute
CONT-006	Task definitions	Les task definitions définissent CPU/mémoire appropriés	Haute
CONT-007	Service discovery	Le service discovery interne (Cloud Map) est configuré	Moyenne

4.3 CI/CD

ID	Contrôle	Critère d'acceptation	Priorité
CICD-001	Pipeline automatisé	Le déploiement est automatisé via CodePipeline/GitHub Actions	Haute
CICD-002	Tests automatisés	Les tests unitaires et d'intégration s'exécutent automatiquement	Haute
CICD-003	Code review	Le merge nécessite une approbation de code review	Haute
CICD-004	Environnements	Les environnements dev, staging, prod sont séparés	Haute
CICD-005	Rollback	Le rollback automatique est possible en cas d'échec	Haute
CICD-006	Blue/green	Le déploiement blue/green est utilisé pour zero-downtime	Moyenne

4.4 Monitoring et logging

ID	Contrôle	Critère d'acceptation	Priorité
MON-001	Logs centralisés	Tous les logs sont centralisés dans CloudWatch	Haute
MON-002	Métriques	Les métriques clés (CPU, mémoire, latence) sont collectées	Haute
MON-003	Alertes	Les alertes sont configurées (erreurs 5xx, latence > 3s)	Haute
MON-004	Dashboard	Un dashboard de supervision est disponible	Moyenne
MON-005	Retention logs	Les logs sont conservés 30 jours	Moyenne
MON-006	Tracing	Le tracing distribué (X-Ray) est configuré	Basse
MON-007	Uptime monitoring	Le monitoring de disponibilité externe est configuré	Haute

5. Sécurité

5.1 Authentification et autorisation

ID	Contrôle	Critère d'acceptation	Priorité
SEC-001	Hachage mots de passe	Les mots de passe sont hachés avec bcrypt (cost 12) ou Argon2	Haute
SEC-002	JWT sécurisé	Les JWT sont signés avec RS256 et contiennent des claims minimaux	Haute
SEC-003	Refresh tokens	Les refresh tokens sont stockés de manière sécurisée	Haute
SEC-004	RBAC	Le contrôle d'accès basé sur les rôles est implémenté	Haute
SEC-005	Rate limiting	Le rate limiting est appliqué (100 req/min par IP pour auth)	Haute
SEC-006	Brute force	La protection contre le brute force est active	Haute

5.2 Communication sécurisée

ID	Contrôle	Critère d'acceptation	Priorité
SEC-007	HTTPS obligatoire	Tout le trafic est en HTTPS (redirection HTTP → HTTPS)	Haute
SEC-008	TLS 1.3	TLS 1.3 est utilisé (TLS 1.2 minimum)	Haute
SEC-009	Certificats SSL	Les certificats SSL sont valides et renouvelés automatiquement (ACM)	Haute
SEC-010	HSTS	Le header Strict-Transport-Security est configuré	Haute
SEC-011	Headers sécurité	Les headers de sécurité sont configurés (X-Frame-Options, CSP, etc.)	Haute

5.3 Protection contre les attaques

ID	Contrôle	Critère d'acceptation	Priorité
SEC-012	WAF	AWS WAF est configuré avec règles OWASP	Haute
SEC-013	Protection XSS	Les entrées sont sanitisées, les sorties encodées	Haute
SEC-014	Protection CSRF	Les tokens CSRF sont utilisés pour les formulaires	Haute
SEC-015	Protection injection SQL	L'ORM avec requêtes paramétrées est utilisé	Haute
SEC-016	Validation entrées	Toutes les entrées sont validées côté serveur	Haute
SEC-017	DDoS protection	AWS Shield est activé	Moyenne

5.4 Gestion des secrets

ID	Contrôle	Critère d'acceptation	Priorité
SEC-018	Secrets Manager	Les secrets sont stockés dans AWS Secrets Manager	Haute
SEC-019	Rotation secrets	Les secrets de base de données sont rotés automatiquement	Moyenne
SEC-020	Variables environnement	Aucun secret n'est en dur dans le code	Haute
SEC-021	Audit secrets	L'accès aux secrets est audité	Moyenne

5.5 Conformité PCI DSS

ID	Contrôle	Critère d'acceptation	Priorité
PCI-001	Pas de stockage carte	Aucune donnée de carte n'est stockée	Haute
PCI-002	Stripe Elements	Le formulaire de carte utilise Stripe Elements	Haute
PCI-003	Tokenization	Les cartes sont tokenisées par Stripe	Haute
PCI-004	Logs audit	Les logs d'accès aux données de paiement sont conservés	Haute

Synthèse des contrôles

Statistiques

Catégorie	Nombre de contrôles	Haute priorité	Moyenne priorité	Basse priorité
Composants logiciels	78	56	18	4
Services tiers	21	18	3	0
Gestion des données	30	24	5	1
Infrastructure	23	19	3	1
Sécurité	21	19	2	0
TOTAL	**173**	**136**	**31**	**6**

Procédure de validation

1. **Phase de développement** : Chaque contrôle doit être implémenté et testé unitairement
2. **Phase de test** : Les tests d'intégration valident les contrôles de haute priorité
3. **Phase de recette** : Tous les contrôles sont vérifiés manuellement avant mise en production
4. **Phase de production** : Les contrôles de sécurité et infrastructure sont monitorés en continu

Matrice de traçabilité

Document source	Section	Contrôles associés
Business Requirements V2	4.1 Authentification	AUTH-001 à AUTH-014
Business Requirements V2	4.2 Profil	PROF-001 à PROF-017
Business Requirements V2	4.3 Location	BOOK-001 à BOOK-025
Business Requirements V2	4.4 Support	SUPP-001 à SUPP-019
Business Requirements V2	4.5 Notifications	NOTIF-001 à NOTIF-012
Business Requirements V2	5.1 Règles métiers	BOOK-015 à BOOK-019, PROF-014 à PROF-017
Business Requirements V2	5.2 Exigences techniques	API-001 à API-005, PAY-*, VIDEO-*, DATA-*, CACHE-*
Business Requirements V2	5.3 Exigences sécurité	SEC-001 à SEC-021
Business Requirements V2	5.4 Internationalisation	I18N-001 à I18N-005
Architecture Definition	5.3 Architecture technologique	INFRA-, *CONT-*, CICD-, *MON-*

Document rédigé par : Deregnaucourt Chrystopher
Date : 02/2026
Version : 1.0